

Padding criptográfico

El relleno resuelve alineación; no aporta autenticidad y puede convertirse en un oráculo si el error es observable.

Material elaborado por el profesor Sergio Gevatschnaider

Contenido

Propósito	3
Resultados de aprendizaje	3
Núcleo teórico	3
Ejemplo PKCS#7	3
Profundización y criterio profesional	3
Caso de análisis	3
Entrega esperada	3
Riesgos y errores frecuentes	3
Actividades de dominio	4
Lista de comprobación	4
Referencias seleccionadas	4

Propósito

El relleno resuelve alineación; no aporta autenticidad y puede convertirse en un oráculo si el error es observable.

Resultados de aprendizaje

1. aplicar PKCS#7.
2. explicar el bloque completo de padding.
3. analizar y mitigar padding oracles.

Núcleo teórico

PKCS#7 completa el último bloque agregando n bytes cuyo valor es n . Si faltan cinco bytes, se añaden cinco bytes 05.

El padding no autentica. Una aplicación que revela si el relleno es válido puede crear un **padding oracle**. Las defensas incluyen:

- preferir AEAD;
- verificar autenticidad antes de procesar;
- uniformar errores;
- evitar diferencias temporales observables.

Ejemplo PKCS#7

Para bloques de 16 bytes, una entrada de 11 bytes recibe cinco bytes 05. Una entrada que ya mide exactamente 16 bytes recibe un bloque completo de dieciséis bytes 10. Esto permite retirar el padding sin ambigüedad. CTR, GCM y ChaCha20 no necesitan este relleno porque operan como flujo sobre la longitud real.

Profundización y criterio profesional

PKCS#7 agrega n bytes con valor n . Para un bloque de 16 bytes, una entrada de 11 bytes recibe cinco bytes 05. Una entrada ya alineada recibe dieciséis bytes 10; sin ese bloque no sería posible distinguir datos terminados en un valor parecido al padding.

Un padding oracle aparece cuando el atacante puede distinguir si el relleno recuperado es válido. Mediante ciphertexts adaptativos, esa señal permite inferir texto sin conocer la clave. El problema no es PKCS#7 aislado, sino una composición sin autenticación y una interfaz que filtra estados internos.

La defensa preferida es AEAD. En compatibilidad heredada deben autenticarse los datos antes de procesarlos, usar claves separadas, errores uniformes y una implementación analizada frente a diferencias temporales.

Caso de análisis

Una API devuelve 400 para padding inválido y 401 para MAC inválido. Modele el oráculo, describa la información filtrada y rediseñe el orden de verificación y la respuesta.

Entrega esperada

Documento activos, actores, propiedad, parámetros, flujo, condición de fallo y decisión recomendada. Separe siempre la garantía criptográfica de la garantía operativa.

Riesgos y errores frecuentes

- creer que padding cifra.

- distinguir errores internos.
- desrellenar antes de autenticar.

Actividades de dominio

1. ¿Por qué se agrega un bloque completo cuando la entrada ya está alineada?
2. ¿Qué necesita observar el atacante?
3. ¿Por qué AEAD reduce esta clase de errores?

Lista de comprobación

- Puedo definir la propiedad y el adversario.
- Puedo explicar parámetros, límites y supuestos.
- Puedo detectar al menos tres configuraciones inseguras.
- Puedo justificar una decisión de arquitectura.
- Puedo relacionar el tema con una norma o especificación primaria.

Referencias seleccionadas

1. NIST SP 800-38A - <https://doi.org/10.6028/NIST.SP.800-38A>
2. Vaudenay, Security Flaws Induced by CBC Padding